

**ESCOLA E FACULDADE SENAI GASPAR RICARDO JÚNIOR
CURSO DE ANÁLISE E DESENVOLVIMENTO DE SISTEMAS**

TRADUDOC: RELATÓRIO TÉCNICO DE AVALIAÇÃO DE VULNERABILIDADES E TESTES DE PENETRAÇÃO

Integrantes:

Bruno Sakamoto, Júlio Figueiredo, Luiz Teles,
Rafael Sinkevicius, Samuel Silva

Turma: TADS4-2025

Semestre: 4º Semestre / 2025

**SOROCABA
2025**

1 INTRODUÇÃO

O sistema avaliado é o TraduDoc, uma plataforma voltada para a tradução automática de documentos (PDF, DOCX e PPTX) mantendo o layout original. A arquitetura integra um backend em Java Spring Boot, frontend em React e aplicação mobile com Expo/React Native, operando em ambiente de nuvem AWS com Docker.

A segurança da informação é vital para garantir a integridade e a confidencialidade dos dados dos usuários, especialmente em sistemas que lidam com documentos sensíveis. Este relatório detalha a análise de vulnerabilidades conduzida via ferramentas automatizadas (OWASP ZAP) e testes de penetração manuais focados na exploração de falhas críticas de configuração e exposição de dados.

2 OBJETIVOS E ESCOPO DA AVALIAÇÃO

2.1 Objetivo

O objetivo desta avaliação foi identificar falhas de segurança na plataforma TraduDoc e realizar a exploração controlada de duas vulnerabilidades específicas, verificando o impacto sistêmico e propondo correções baseadas em boas práticas da indústria.

2.2 Escopo da Avaliação

A análise de segurança abrangeu:

- Endpoints públicos da API de tradução.
- Mecanismos de autenticação (JWT e OAuth2).
- Infraestrutura de containers e gerenciamento de sessões.
- Comunicação entre frontend e backend via HTTPS.

O escopo excluiu explicitamente ataques de engenharia social, testes físicos de infraestrutura e análise de serviços externos de terceiros.

3 METODOLOGIA

3.1 Configuração do Ambiente e Ferramentas

A varredura automatizada foi conduzida utilizando o OWASP ZAP 2.16.1 em ambiente Ubuntu 20.04. O sistema foi testado sob uma configuração de rede simulada que espelha o ambiente de produção na AWS, permitindo a detecção de Headers de segurança ausentes e falhas de configuração em endpoints REST.

3.2 Pentest: Exploração das Vulnerabilidades Seleccionadas

1. Falha de Configuração de CORS e CSP: Identificou-se que a política de Content Security Policy (CSP) estava ausente, o que permite ataques de injeção e manipulação de scripts. A exploração foi simulada através de um ataque de Cross-Site Request Forgery (CSRF), utilizando a ferramenta BeEF para manipular requisições autenticadas sem o consentimento do usuário.

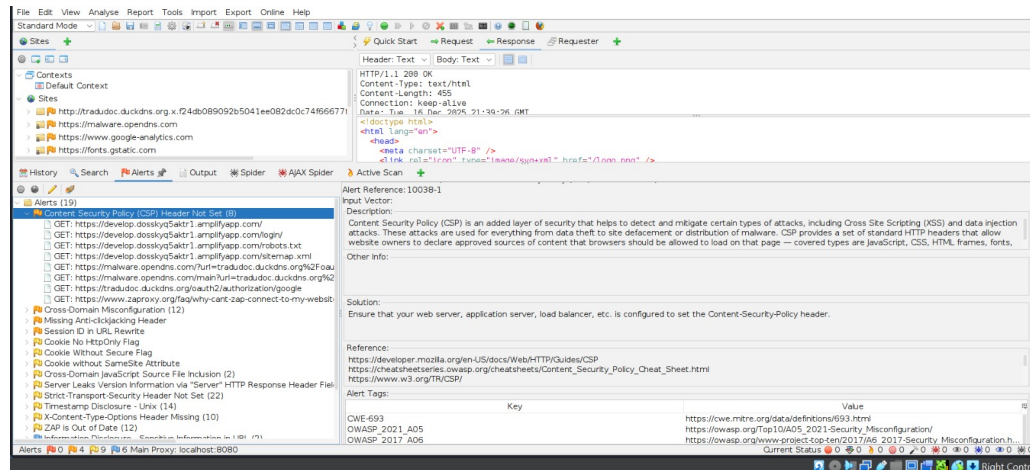


Figura 1: Alerta do OWASP ZAP indicando a ausência do cabeçalho CSP.

2. Exposição de Dados Sensíveis em URL: O scanner detectou o vazamento de tokens de sessão através da técnica de URL Rewrite. A vulnerabilidade foi validada manualmente através da interceptação de tráfego HTTP, permitindo a captura de identificadores de sessão em texto claro.

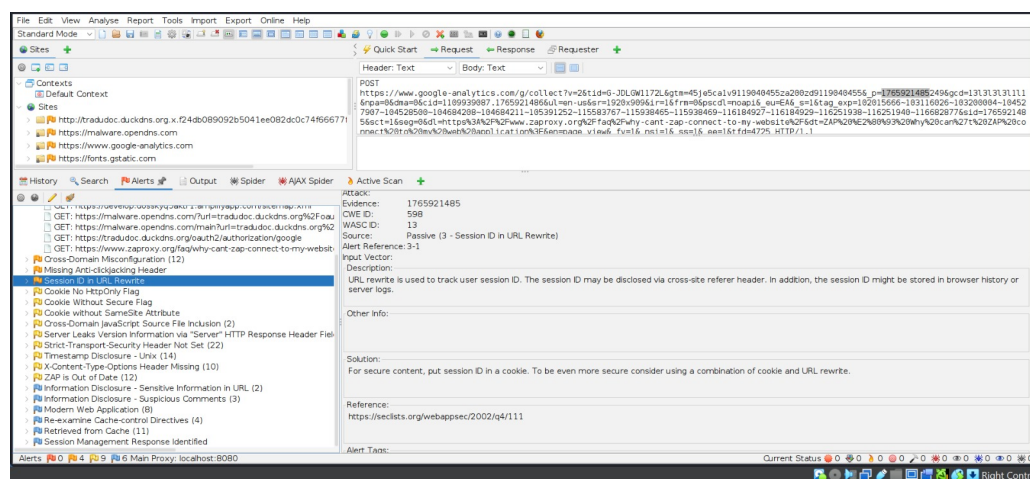


Figura 2: Identificação de Session ID exposto em parâmetro de URL.

4 RESULTADOS

4.1 Resultados da Varredura Automatizada

Durante a fase automatizada, destacaram-se falhas críticas de configuração que facilitariam ataques de interceptação e sequestro de sessão:

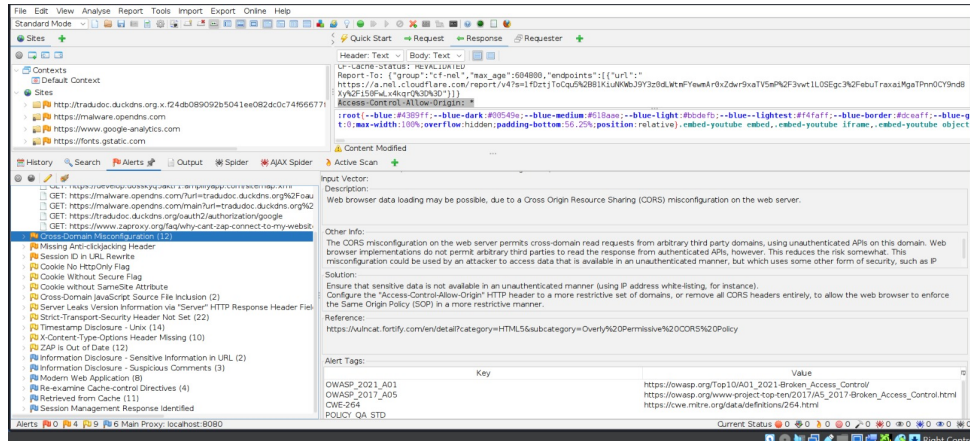


Figura 3: Detecção de Cross-Domain Misconfiguration (CORS).

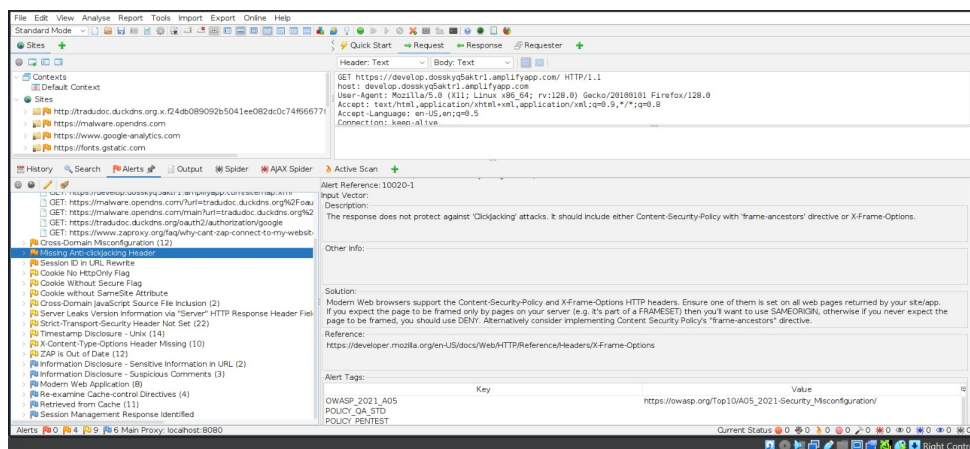


Figura 4: Ausência de Headers Anti-clickjacking.

4.2 Resultados do Pentest

A exploração manual confirmou que atacantes poderiam manipular conteúdos traduzidos através da falta de CORS e assumir sessões de usuários legítimos devido ao vazamento de tokens na URL. A severidade é considerada **ALTA**, dado o risco de comprometimento da confidencialidade dos documentos processados.

5 DISCUSSÃO

As vulnerabilidades detectadas, como a falta de CSP e o vazamento de Session IDs, estão diretamente relacionadas à categoria ****A05:2021 – Security Misconfiguration**** do OWASP Top 10. A causa raiz reside na ausência de filtros globais no backend para imposição de Headers de segurança e na configuração inadequada do gerenciamento de sessões do servidor de aplicação.

Para mitigação, recomenda-se:

- Implementação de políticas CSP restritivas.
- Configuração de cookies com as flags *HttpOnly* e *Secure*.
- Desativação total da reescrita de URL para transporte de sessões.

6 CONCLUSÃO

O sistema TraduDoc demonstra uma arquitetura funcional moderna, porém apresenta riscos críticos que podem ser explorados por agentes externos. A correção imediata das configurações de Headers e do transporte de tokens elevará o nível de segurança da plataforma para padrões industriais aceitáveis, garantindo a proteção dos ativos de informação da LabWare.

7 REFERÊNCIAS

[1] TraduDoc: Plataforma Integrada de Tradução de Documentos. Artigo Científico - Projeto Integrador IV SENAI. 2025.

[2] OWASP Foundation. OWASP ZAP Documentation. Disponível em: <https://www.zaproxy.org/docs/>. Acesso em: 16 dez. 2025.